

SECCIÓN 2.6



Controles de seguridad y control de acceso

Temas de esta sección:

- Qué es un control de seguridad y para qué sirve
- Tipos: preventivos, detectivos y correctivos
- Cómo aparecen los controles en alertas SOC
- Actividad bloqueada ≠ caso cerrado
- Qué es control de acceso: autenticación vs autorización
- Principio de mínimo privilegio y cuentas privilegiadas
- Fallas comunes y riesgo residual

2.6 | Tipos de controles: preventivos, detectivos y correctivos



Una forma práctica de clasificar los controles es según el momento en que actúan:

PREVENTIVOS	DETECTIVOS	CORRECTIVOS
Buscan evitar que algo ocurra.	Buscan identificar actividad sospechosa o maliciosa.	Buscan reducir impacto, contener o recuperar después de un evento.
▸ MFA	▸ SIEM	▸ Aislamiento de endpoint
▸ Firewall	▸ EDR	▸ Reset de contraseña
▸ Segmentación de red	▸ IDS/NDR	▸ Revocación de sesiones
▸ Gestión de parches	▸ UEBA	▸ Restauración desde backup
▸ Políticas de contraseñas	▸ Reglas de correlación	▸ Bloqueo de IP/dominio
Si un atacante tiene la contraseña pero no puede completar el MFA, el control preventivo redujo el riesgo. Pero el SOC igual debe revisar el intento.	El SIEM detecta 30 intentos fallidos + login exitoso. No impide el acceso, pero genera la alerta que activa al analista.	El analista SOC puede recomendar y documentar estas acciones, pero generalmente las ejecuta el equipo de respuesta o IT tras evaluación.

Error crítico: cerrar una alerta automáticamente porque la herramienta dice 'Blocked'

Alerta EDR:

Alert: Malware detected

Action: Blocked

Host: USER-LAP-203

File: invoice_update.exe

Path: Downloads

Related email: Yes

Preguntas que todavía quedan abiertas:

¿Cómo llegó el archivo?

¿Otros usuarios recibieron el mismo correo?

¿El archivo llegó a ejecutarse parcialmente?

¿Hubo otros archivos descargados?

¿El hash aparece en otros endpoints?

¿Hay actividad previa o posterior?

¿Corresponde activar playbook de phishing?

El bloqueo reduce el impacto, pero no elimina la necesidad de validar el alcance. Un archivo bloqueado puede ser parte de una campaña más amplia.

2.6 | Control de acceso: autenticación, autorización y mínimo privilegio



El control de acceso define quién puede acceder a qué, bajo qué condiciones y con qué permisos.

AUTENTICACIÓN	El proceso de verificar la identidad. Confirma quién es el usuario.	<i>Resultado de autenticación exitosa: 'El sistema aceptó que sos quien decís ser.'</i>
AUTORIZACIÓN	El proceso de definir qué puede hacer ese usuario ya autenticado.	<i>Un analista financiero puede autenticarse pero no debería poder exportar toda la DB de clientes.</i>
MÍNIMO PRIVILEGIO	Un usuario, cuenta o proceso debería tener solo los permisos necesarios para cumplir su función.	<i>Permisos excesivos amplían el impacto de cualquier compromiso. Una cuenta de marketing NO debería tener acceso a repositorios productivos.</i>

Concepto clave: Acceso exitoso solo significa que el sistema aceptó la autenticación. No significa que quien está detrás de esa sesión sea quien dice ser.

2.6 | Ejemplo: cuenta privilegiada con actividad anómala



Alerta crítica:

Alert:	Privileged account unusual login
User:	admin.backup
Source IP:	Unknown
Time:	03:14 AM
MFA:	Not enabled
Login:	Success
After:	Access to backup server
	Deletion of backup job
	New scheduled task created

Por qué este caso es crítico:

- ⚠ Cuenta privilegiada — admin.backup
- ⚠ Login desde IP desconocida
- ⚠ Sin MFA habilitado
- ⚠ Acceso a servidor de backups
- ⚠ Eliminación de job de backup
- ⚠ Posible preparación para impacto posterior

El control de acceso deficiente (sin MFA en cuenta privilegiada) amplifica el riesgo y el posible impacto.